Security Documentation

Contents

Document Control 2
1. Assessment Scope and Limitations 2
2. Assets, Classification and Handling 2
3. Security Architecture and Control Status 3
4. Threat Model 4
5. Source-Based Risk Register 4
6. Required Production Configuration 6
7. Security Verification and Evidence Plan 7
8. Incident and Recovery Procedure 8
9. Approval Record 8

Document Control

Attribute	Value
Document ID	CRM-SEC-001
Product / customer	AAP Fleet Management System / Addis Ababa Police Commission
Version / issue date	1.0 / 13 November 2026
Publisher	Selfmade Cloud Solutions
Source baseline	`5974cf7addfef5d5cfc8fde325fc964343557a2f`
Planned deployment	On-premise Commission server; more than 700 vehicles and 500 users
Technical contact	Natnael Tilaye / natnaeltilaye30@gmail.com
Status	Source-based security design/risk record; not a penetration-test or compliance certificate
Security approver	Commission security owner and independent assessor: TO BE CONFIRMED

1. Assessment Scope and Limitations

This optional application document is included because deployment approval needs an accurate account of controls and outstanding assurance. The review covers source architecture, custom APIs, hardware adapter, persistence and repository Docker packaging. It does not establish INSA compliance, certify absence of vulnerabilities, or prove the deployed controls exist.

No live penetration test, production network review, image/dependency vulnerability scan, security configuration audit or disaster-recovery exercise was performed in preparing this dossier. Focused local unit tests are recorded separately. Operational secrets, detailed exploit demonstrations, real network topology and test credentials are intentionally excluded from public Git documentation.

Production security sign-off is not established by the evaluated source. Functional integration success does not resolve the legacy API authorization and transaction-integrity findings below. Remediate and independently retest required controls before broad production use; any exception requires explicit Commission security acceptance, compensating controls and expiry.

2. Assets, Classification and Handling

The following classification is proposed for Commission approval, not a claim that a formal government classification has already been assigned.

Asset	Proposed handling	Risks
Vehicle GPS/history, device associations and fleet status	Restricted operational information	Movement disclosure, operational profiling, falsified observations
Employee/driver/custodian identity and assignments	Restricted personnel information	Privacy loss, unauthorized attribution
Repair, inspection, faults and handover evidence	Controlled operational records	Safety/maintenance misrepresentation, missing evidence

Asset	Proposed handling	Risks
Fuel, quota, expense, invoice and asset data	Restricted financial/administrative records	Unauthorized approval, double posting, fraud and disclosure
Credentials, API secrets, site encryption key and database access	Highly restricted secrets	Full compromise, decryption or unauthorized ingestion
Backups, reports, attachments and logs	At least the highest included data sensitivity	Uncontrolled replicas, residual sensitive data
Source, image, dependencies and build scripts	Controlled integrity; public source subset permissible	Supply-chain change, exposed configuration or secrets

On-premise hosting does not eliminate outbound disclosure through provider APIs, external maps, mail, dependency services, telemetry previews or exported backups. Approve every external dependency and minimize shared data. Do not publish live device identifiers, operational coordinates or signed network diagrams with this dossier.

Retention periods, deletion approval, legal holds, export authority, archive location and backup expiry must be assigned by the Commission. The app does not provide a complete enforced lifecycle policy for every data category. A scheduled backup is not a substitute for approved retention and tested recovery.

3. Security Architecture and Control Status

Control	Observed capability	Limitation / required evidence
Authentication	Frappe session/token mechanisms; protected methods generally require authenticated user	Final account policy, session settings and integration token lifecycle not inspected
Browser CSRF	Client sends Frappe CSRF token when available	Do not disable CSRF; fix GET-capable mutations and verify final framework settings
Authorization	Generic resources use DocType permissions; hardware methods have explicit role/vehicle checks	Many legacy methods use get_all/ ignore_permissions; not uniform record-level enforcement
Provider secret storage	Password field; read/list omit key; preview literal-key redaction	Site key protection and response/log redaction must be reviewed; not whole-DB encryption
Provider request isolation	Public-address DNS checks, no redirects	DNS re-resolution/rebinding risk and HTTP allowed; require HTTPS/egress allowlist
Response validation	2 MiB body limit, numeric/time validation and connect/read timeouts	No hard total stream deadline; no provider signature/future-time policy
Device association	Unique IMEI mapping, disabled-vehicle rejection	Credential is not bound to individual IMEI; a stolen integration token has broader scope
Poll recovery	Site Redis lease, bounded job, watchdog and per-vehicle status	Best effort; no formal exactly-once or automatic provider failover guarantee
Audit	Standard metadata, some comments/ versions; config track_changes enabled	Not complete tamper-evident action logging; direct DB writes may bypass versions

Control	Observed capability	Limitation / required evidence
Deployment	Application/asset build baked into shared service image	Final hardening, SBOM, digest/ signature, network and volume settings unverified

4. Threat Model

Threat / boundary	Potential impact	Required response
Compromised normal user calling methods directly	Cross-vehicle disclosure or unauthorized writes	Server-side role/record checks and adversarial negative tests
Claimed approver role or repeated approval request	False fuel approval or repeated quota consumption	Trusted approver derivation, valid state transitions, atomic/idempotent posting
Stolen service token or replayed sensor message	Forged location/fuel and history growth	Narrow device scopes, rotation, replay/ idempotency/freshness design
Malicious provider URL or DNS change	Internal network access, credential disclosure	HTTPS allowlist and network-level egress enforcement
Poisoned/slow/large provider response	Wrong fleet decisions, resource exhaustion	Validation, total deadline, limits, rate/ backoff and load tests
Exposed Redis/MariaDB/sites volume	Broad data/secret compromise	Private networks, restricted accounts, encryption and host hardening
Wrong or tampered image/dependency	Supply-chain compromise or broken service	Controlled builds, resolved SBOM, scan, digest and artifact verification
Public file, export, map or mail misuse	Operational/personnel data leakage	Access-controlled storage, recipient/ destination review and auditing
Container/site failure or destructive migration	Lost records and extended outage	Encrypted consistent backup, restore rehearsal and approved rollback

This threat model is an engineering starting point. The Commission assessor must refine adversary assumptions, site isolation, physical server access and national/organizational assessment criteria in the controlled review.

5. Source-Based Risk Register

Severity is provisional engineering priority, not a CVSS score or a claim of a live exploit. Entries marked Required remain open until evidence is attached. References are relative to the evaluated source revision.

SEC-01: Legacy API Role and Record Authorization

Priority: High. Status: Required remediation/testing. `api/vehicle.py:get_vehicle_dashboard` reads records and related personnel/financial context without an explicit record permission check at entry. `api/issue.py` uses broad searches and several `ignore_permissions` writes. Other fleet/report/expense endpoints need systematic review. Frappe authentication alone does not authorize every authenticated user to every record, and `get_doc` alone is not `check_permission`.

Remediation: inventory each method, define role/action/record scope, call appropriate permission checks before reading/returning or writing, apply permission-aware queries and narrowly justify any bypass. Test authorized/unauthorized users across companies, vehicles, guessed document IDs, reports, files and batch IDs. Owner: application engineering plus Commission access owner. Closure: signed negative-test matrix with no unauthorized data/action success.

SEC-02: Fuel Approval Authority and Repeated Posting

Priority: High. Status: Required remediation/testing. `api/fuel.py:approve_refueling(name, role)` branches on caller-supplied `role`, saves with ignored permissions and can increment consumed quota whenever the resulting state is Approved. It does not itself establish trusted approver authority or robust once-only financial posting. Related create/reject/quota update paths also require review.

Remediation: derive approver authority on the server, enforce the current allowed state and approval sequence, validate values and use atomic/locked once-only consumption posting. Test repeated/concurrent approvals, forged role values, wrong employee/department, direct calls and rollback. Owner: engineering/finance. Closure: unauthorized decisions denied and consumption changes exactly once in signed reconciliation evidence.

SEC-03: Integration Credential Scope, Replay and Mutation Semantics

Priority: High. Status: Required design and tests. Central telemetry role gates are not per-device scope gates. An integration user can submit a mapped IMEI beyond one assigned physical device unless additional deployment controls exist. The central method allows GET and POST and lacks an action-specific GET mutation guard. Stable-hash deduplication applies to automatic polling, not all push/manual requests. Update/delete can alter history; deleting a batch is not a demonstrated live-snapshot rebuild.

Remediation: restrict mutation to POST; bind service principals to allowed devices/vehicles/actions; define idempotency/replay and timestamp policy; audit history-changing actions and reconcile snapshots. Separate device service accounts from administrators. Test revoked tokens, forged IMEI/batch, cross-site access, duplicates and out-of-order/future messages. Owner: integration/security engineering. Closure: signed scoped-ingestion and integrity tests.

SEC-04: Provider SSRF, Transport and Resource Boundaries

Priority: High. Status: Partially controlled; hardening required. `api/hardware.py:fetch_configuration` checks current DNS results for public addresses and disables redirects, but requests may resolve the host again. `_validate_test_endpoint_url` permits HTTP. Requests connect/read timeout settings do not bound total slow-stream duration. Failure retries use the shortest polling interval without a circuit breaker.

Remediation: approved HTTPS-only provider hosts, restricted outbound proxy/firewall, certificate validation, total request deadline and appropriate rate/backoff limits. Consider connection binding with hostname/TLS correctness if relying on address validation. Test IPv4/IPv6 private, loopback/link-local, DNS changes, redirect chains, slow bodies and failure storms. Owner: engineering/network operator. Closure: final egress configuration and adversarial adapter tests.

SEC-05: Preview, Stored Response and Administrative Data Exposure

Priority: High. Status: Required review. Preview redacts literal configured API-key occurrences, but provider responses may contain other secrets or sensitive fleet objects. Manual Run stores a response sample and returns samples through a separate path. RAW/discovery can include other devices even when a vehicle test filters its parsed output. `api/settings.py:update_setting` writes allowed global defaults without a uniform explicit manager check in that branch.

Remediation: enforce administrative setting roles; minimize provider account scope; use structured redaction in all return/storage/log paths; return only required vehicle data; review config export/print/share permissions. Test reflected/transformed credentials, other vehicle objects, raw/sample persistence and ordinary-user setting mutation. Owner: application/security engineering. Closure: redaction/access tests and approved information-sharing policy.

SEC-06: Docker Supply Chain and Deployment Baseline

Priority: High. Status: Required release evidence. The Dockerfile uses a tag, copies the app directory and assumes a particular Node location. The override is not a full network/secrets/backup/hardening stack. No built production image, SBOM, vulnerability report, signature, digest or fresh-container test was available in this preparation environment.

Remediation: controlled clean build context, resolve supported patched platform versions, lock dependencies, generate SBOM, scan image/dependencies, record digest/provenance and apply the same image to all services. Harden non-root execution, capabilities, writable mounts, secrets and private networks using a compatibility-tested final stack. Owner: DevOps/security. Closure: release manifest and clean install/upgrade evidence. Do not upgrade framework versions without compatibility tests.

SEC-07: Demo Data, Retention and Recovery

Priority: High. Status: Required operating controls. `install.py:after_install` attempts demo seeding. Telemetry growth can be high for more than 700 vehicles; no complete approved purge/aggregation/retention policy is established. Protecting database dumps without the corresponding files and site encryption key is incomplete recovery.

Remediation: prevent or carefully remove seeded demonstration records in an approved release flow; classify data, approve retention/aggregation, encrypt off-instance backups and test database/files/key restore. Do not run a broad demo deletion against production without reviewing exactly what it deletes. Owner: information owner/operations. Closure: clean-data sign-off, capacity/retention test and witnessed restore meeting approved RPO/RTO.

SEC-08: Audit, Monitoring and Assurance Coverage

Priority: Medium-High. Status: Required evidence. Existing version/comments/error/status records are not a complete immutable security audit trail. Focused unit tests are not a full API permission, concurrency, load, accessibility or penetration-test suite. Per-site audit checks schema/imports, not security. Final dependency/runtime patch status has not been assessed here.

Remediation: central protected logging for authentication, privileged changes, exports, device mapping, approvals and history mutations; synchronized time, retention and alerting; full role-negative tests, source/dependency/image scans and independent penetration test. Owner: security operations/QA. Closure: approved reports with resolved findings and alert demonstration.

SEC-09: Time, Provider Trust and Business Guard Semantics

Priority: Medium-High. Status: Required policy/testing. Provider timestamps do not carry a mandatory timezone or accepted skew bound. A successful poll can return stale data. Financial closure accepts certain linked invoice statuses but does not itself prove mandatory invoice presence or full settlement.

Remediation: approve timezone/skew/staleness handling, validate calibrated units and provider provenance, display/alert on measurement age and align closure with Commission finance policy. Test future-dated samples and missing/unpaid invoice cases. Owner: integration, workshop and finance owners. Closure: policy and corresponding automated/UAT evidence.

6. Required Production Configuration

These are operator implementation requirements, not verified deployed settings.

1. Serve approved application/device interfaces through HTTPS; validate TLS certificates, host routing and allowed origins. Expose only necessary ingress, never backing DB/Redis ports to client networks.
2. Use named individual accounts, least-privilege roles and approved company/vehicle scope. Disable unused/demo accounts; review default Administrator access. Configure available framework password/session/MFA controls to Commission policy and verify them.

3. Issue service credentials only to approved integrations. Use separate administrative and device identities, device scopes, rotation/revocation and rate limits. Keep API secrets out of query strings and browser storage.
4. Store secrets outside source/image layers. Protect the Frappe site encryption key, database accounts, provider keys and backup keys with restricted access and rotation procedures. Do not claim full disk/database encryption from the Password field alone.
5. Restrict provider egress by approved destination. Review external map/mail behavior and provider account data scope for operational sensitivity.
6. Apply compatible supported platform patches; scan final application dependencies and image, retain SBOM/digest and controlled source provenance.
7. Place DB, Redis and application services on controlled private networks. Test container user/capability/resource restrictions and writable paths; do not apply incompatible blanket read-only flags without testing.
8. Back up database, files and protected site configuration/key consistently; encrypt and keep a protected off-instance copy. Test restore and rollback before release.
9. Collect protected, redacted logs and alerts for failed login, unauthorized API attempts, mapping/config changes, approval/export/history mutations, stale sensors, provider outage, worker backlog and storage pressure.
10. Execute a release change window, migration per site, clean schema audit, smoke test and explicit security acceptance. Do not expose a production service merely because containers are running.

7. Security Verification and Evidence Plan

Evidence ID	Required exercise	Pass criterion
SE-01	Role/action/record negative matrix across workshop, Desk and direct APIs	No unauthorized data or mutation; checks use real low-privilege accounts
SE-02	Fuel/work-order financial integrity and concurrency	Trusted approval path; once-only posting; approved closure/settlement semantics
SE-03	Integration credential/IMEI/replay tests	Rejected cross-device/site, revoked, duplicate and invalid/future samples per policy
SE-04	Provider network and response attacks	Denied forbidden destinations; bounded resource use; no credential leakage
SE-05	Dependency/image/configuration scans and independent penetration test	Findings resolved or explicitly accepted under policy; final digest identified
SE-06	Fresh Docker site install, upgrade and asset/worker tests	Correct schema/services/assets without manual hidden fixes
SE-07	Load and growth exercise above the planned minimum fleet/user population	Meets approved p95/lag/error/storage criteria; threshold values agreed before testing
SE-08	Backup restore, worker/provider outage and incident rehearsal	Meets approved RPO/RTO; integrity reconciled and alerts acted upon
SE-09	File/export/report/mail/map handling and retention review	Only approved data destinations, recipients and retention behavior

Maintain reports in a controlled evidence register with test environment, source SHA/image digest, tools and versions, tester, date/time/timezone, sanitized results, reviewer and remediation references. Never publish operational credentials or detailed exploit payloads in a public PR.

8. Incident and Recovery Procedure

1. Operator reports suspected compromise, unauthorized change, leaked key, abnormal GPS/fuel or outage through the Commission-approved channel. Production incident contacts/on-call hours remain to be confirmed; technical contact is listed above.
2. Security lead triages impact, preserves timestamps and protected logs, identifies affected sites/accounts/devices and appoints an incident owner.
3. Contain using scoped account/token revocation, disabled affected integration, restricted ingress/egress or isolated services. Preserve evidence; do not erase records to hide errors.
4. Protect backups and investigate image/source, identity, provider and database events. Rotate compromised keys including dependent secrets as appropriate; site encryption-key rotation needs a tested Frappe-compatible procedure.
5. Restore clean source/image and verified data/files/configuration under change control. Reconcile transactions and sensor histories; restoring an older dump may lose later legitimate writes.
6. Verify security fixes, required negative tests and operational health before restoring access. Notify affected parties/authorities according to the Commission's approved obligations; no unverified statutory deadline is asserted here.
7. Record root cause, evidence retention, corrective actions, owners and follow-up assessment. Update this dossier when security design or scope changes.

9. Approval Record

Commission security owner: TO BE CONFIRMED. Independent assessor/report ID: TO BE CONFIRMED. Infrastructure hardening evidence: TO BE CONFIRMED. Open-risk dispositions with owner/expiry: TO BE CONFIRMED. Authorized submission/production decision, signature and date: TO BE CONFIRMED.

This document must remain truthful after remediation: update status and attach evidence rather than silently removing risks or treating the dossier itself as assurance. Final assessment criteria and certificate decisions belong to INSA and the authorized Commission process.